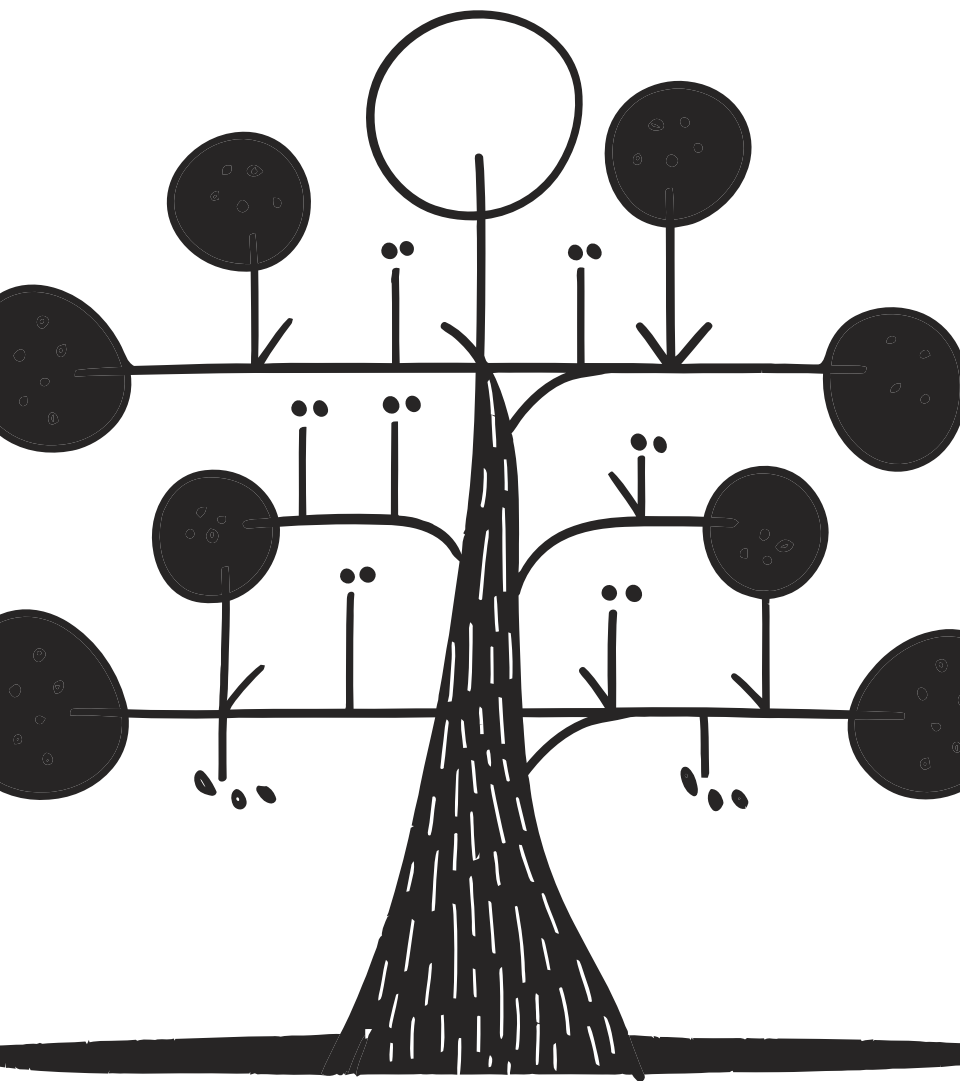




Teoria R2 — BBDD en PHP amb PDO

La base tècnica per a persistir dades estructurades en un projecte PHP real: connexió, consultes i seguretat mínima.

CICLE FORMATIU · R2M9

Persistència: tres nivells molt diferents

1

Dada temporal

Viu mentre s'executa la petició. Es perd en acabar el script.

2

Dada de sessió

Viu mentre dura la sessió de l'usuari. Desapareix en tancar el navegador o expirar.

3

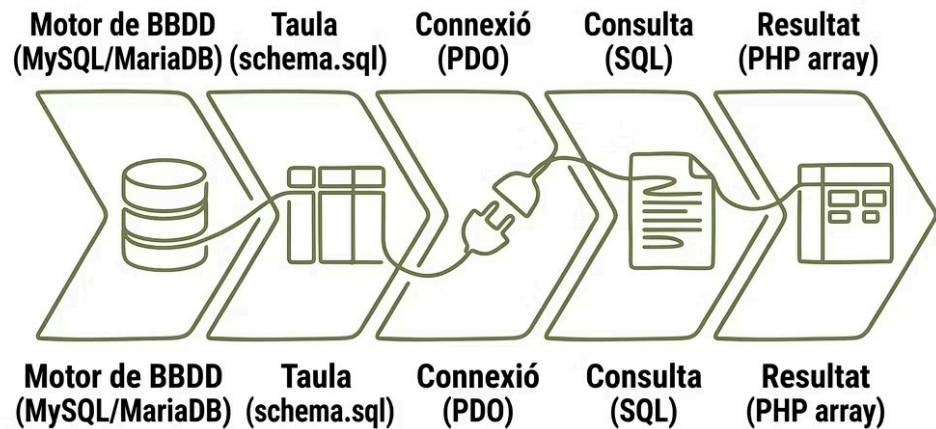
Dada persistent

Viu en una BBDD. Sobreviu reinicis, sessions i desplegaments.



Sessió i cookie **no substituïxen** una BBDD. Guarden estat d'usuari, no dades de negoci duradores.

Les peces mínimes d'una BBDD en PHP



- **Motor:** MySQL o MariaDB allotja les dades.
- **Taula:** definida en un fitxer `schema.sql`.
- **Connexió:** oberta per PDO amb credencials.
- **Consulta:** INSERT o SELECT preparats.
- **Resultat:** array PHP llest per mostrar.

Estructura de fitxers recomanada

`config/database.php`

Credencials i constants de connexió. **Fora del repositori.**

`database/schema.sql`

Definició de taules. Sí que va al repo.

`src/Connexio.php`

Classe o funció que retorna el PDO. Reutilitzable.

`public/crear.php`

Rep el formulari, valida i executa INSERT.

`public/l·listar.php`

Executa SELECT i mostra les dades amb HTML segur.

`.env.example`

Plantilla pública sense secrets reals. El `.env` real va al `.gitignore`.



Connexió amb PDO

El DSN especifica el motor, l'amfitrió i el nom de la base de dades. El mode d'errors llança excepcions en lloc de fallar en silenci.

```
$dsn = 'mysql:host=localhost;dbname=projecte;charset=utf8mb4';

$pdo = new PDO($dsn, $user, $password, [
    PDO::ATTR_ERRMODE => PDO::ERRMODE_EXCEPTION,
    PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC,
]);
```

- i Les credencials `$user` i `$password` vénen del fitxer de configuració, **mai** escrites directament al codi que pugues al repo.

Crear dades: INSERT amb prepare i execute

Les dades de formulari **sempre s'han validat prèviament**. Després s'inserixen amb paràmetres, sense concatenar res.

```
$stmt = $pdo->prepare(  
    'INSERT INTO reserves (nom, estat) VALUES (:nom, :estat)'  
);  
$stmt->execute([  
    'nom' => $nom,  
    'estat' => 'pendent',  
]);
```

prepare()

Envia la consulta al motor. Els `:placeholders` queden pendents.

execute()

Lliga els valors reals i executa. El motor separa codi de dades.

Mai concatenar

`'... VALUES ("'.$nom.'")'` obri la porta a SQL Injection.

Llegir dades: SELECT i eixida HTML segura

```
$reserves = $pdo  
->query('SELECT nom, estat FROM reserves')  
->fetchAll(PDO::FETCH_ASSOC);
```

Mostrar les dades

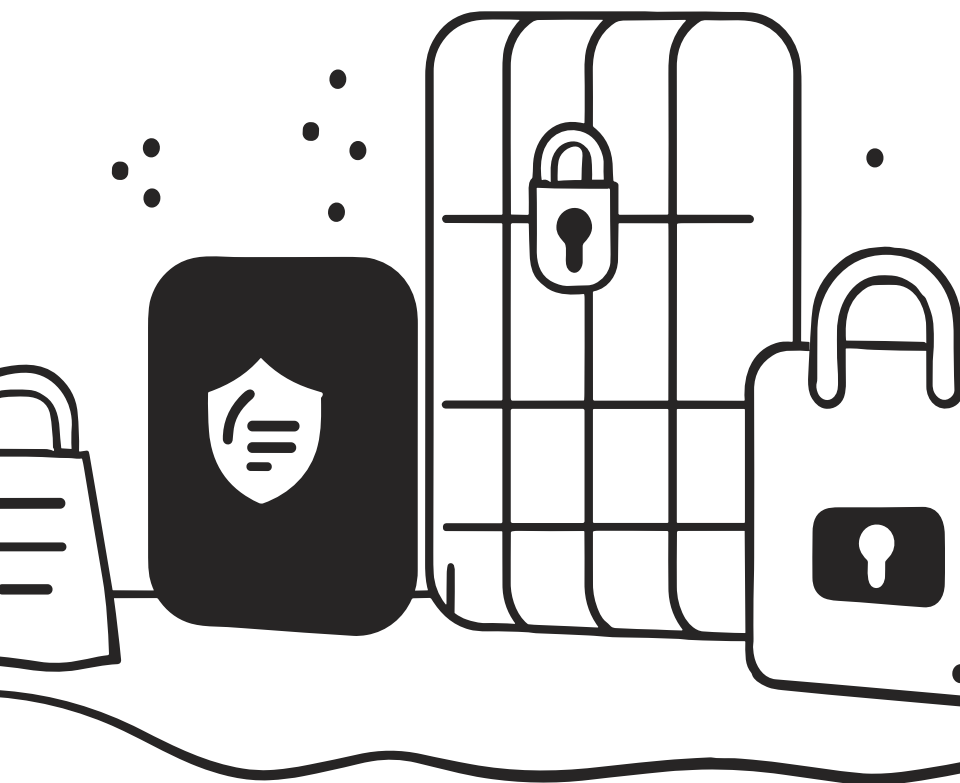
```
<?php if (empty($reserves)): ?>  
  <p>Encara no hi ha reserves.</p>  
<?php else: ?>  
  <?php foreach ($reserves as $r): ?>  
    <p>  
      <?= htmlspecialchars($r['nom']) ?>  
      — <?= htmlspecialchars($r['estat']) ?>  
    </p>  
  <?php endforeach; ?>  
<?php endif; ?>
```



htmlspecialchars() és obligatori en qualsevol dada que prové de la BBDD i s'injecta a l'HTML. Evita XSS.



Comprova sempre el cas de taula buida: l'usuari ha de veure un missatge clar, no una pàgina en blanc.



Seguretat mínima: quatre regles

1

No concatenes dades d'usuari al SQL

Usa sempre `prepare` i `execute` amb paràmetres.

2

No pugis secrets al repo

Credencials al `.env`, mai al codi. Afig `.env` al `.gitignore`.

3

No mostres errors interns a producció

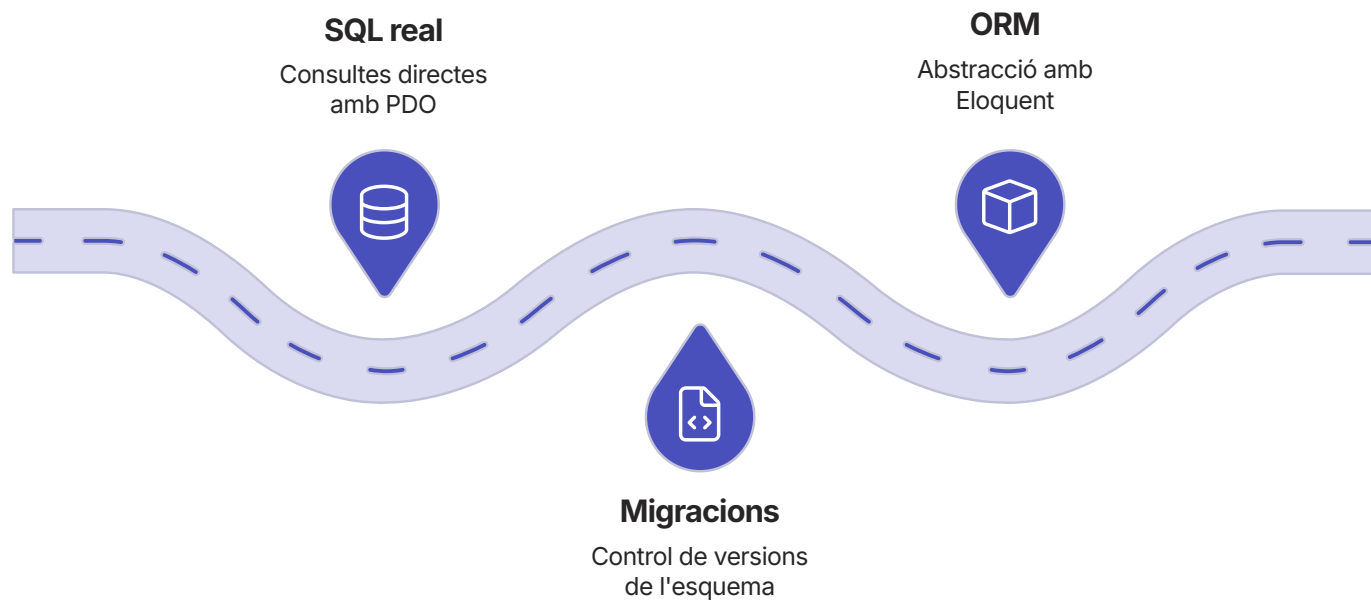
Captura les excepcions i mostra missatges genèrics a l'usuari.

4

Escapa sempre l'eixida HTML

`htmlspecialchars()` en tot el que prové de la BBDD o de l'usuari.

Pont cap a R3: el que ve després



Haver vist SQL real fa que les capes d'abstracció tinguin sentit quan apareguen.

Vocabulari que encontraràs a R3

- **Migration:** fitxer PHP que crea o modifica taules de manera versionada.
- **Seeder:** pobla la BBDD amb dades de prova de manera reproduïble.
- **ORM:** mapeja taules a objectes PHP i genera el SQL automàticament.

✓ Tot el que practiques ara amb PDO cru és la base que farà comprensible qualsevol ORM.

Preguntes de tancament

Reflexiona sobre el teu projecte actual abans de la pròxima sessió:

1 Quina dada del teu projecte mereix persistir en BBDD?

Pensa en dades de negoci que han de sobreviure entre sessions o usuaris.

3 On tens separada la connexió a BBDD?

Ha d'estar en un fitxer propi, fora de `public/`.

2 Per què sessió o cookie no són suficients per a eixa dada?

4 Com comproves una alta i una lectura reproduïbles?

Esborra la taula, torna a executar i verifica que el resultat és sempre el mateix.